Лабораторная работа № 3

Защита интеграционной платформы

Назармамадов Умед Джамшедович Талебу Тенке Франк Устон Бахи Сиди Али Темассини Пакавира Арсениу Висенте Луиш Алькамаль Ибрахим Мохсейн Мохаммед Али Баптишта Матеуж Андре

2026-11-09

Содержание I

1. Информация
2. Ход работы
3. Результаты

Section 1

Информация

Состав команды

Группа НФИбд-02-23

Участник	Номер или роль
Назармамадов Умед Джамшедович	Докладчик
Талебу Тенке Франк Устон	1032224534
Бахи Сиди Али Темассини	1032234211
Пакавира Арсениу Висенте Луиш	1032225105
Алькамаль Ибрахим Мохсейн Мохаммед Али	1032225432
Баптишта Матеуж Андре	1032225099

Цель и схема работы

Мы исследовали атаки на три узла интеграционной платформы и устранили их последствия.

Узел	Адрес	Последствие
Bitrix	10.10.1.33	Подмена главной страницы
GitLab	10.10.2.18	Обратное соединение Meterpreter
WSO2 API Manager	10.10.2.27	Посторонняя учётная запись

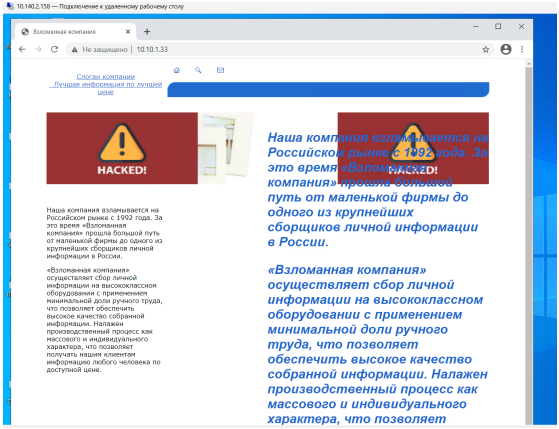
Для расследования мы сопоставили события **ViPNet IDS NS**, журналы приложений и активные соединения на серверах.

Section 2

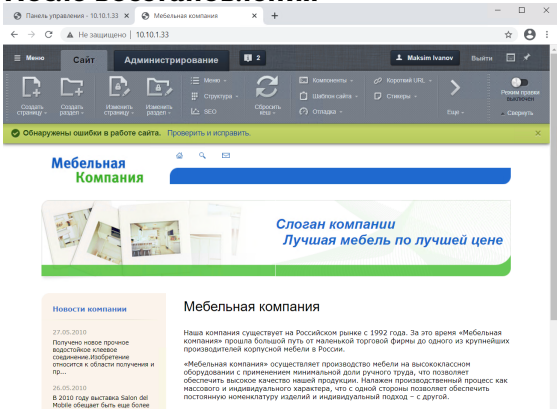
Ход работы

Bitrix до и после восстановления

До восстановления

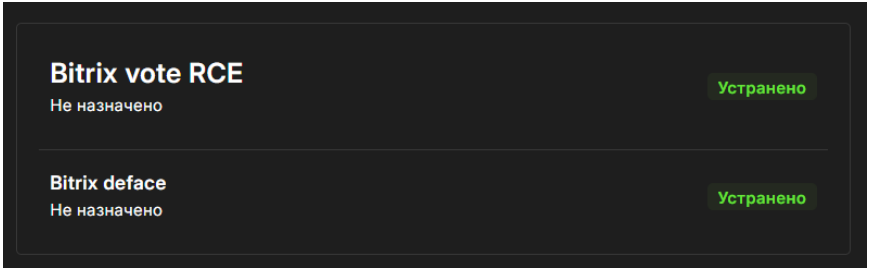


После восстановления



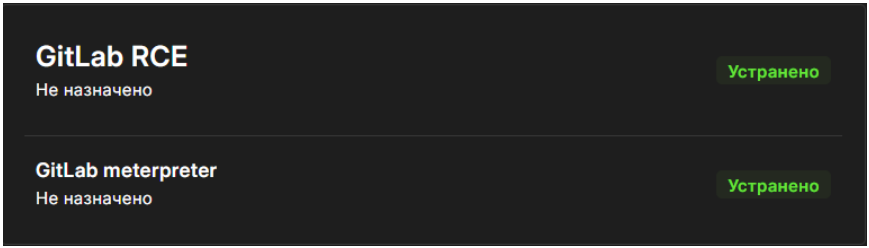
Bitrix. Проверка устранения

- Закрыли соединения с `195.239.174.11`.
- Ограничили доступ к модулю `vote`. Контрольный запрос вернул **HTTP 403**.
- Сняли биты SUID и SGID с файла `apache_restart`.



GitLab. Завершение сессии Meterpreter

- ViPNet обнаружил попытку эксплуатации **CVE-2021-22205**.
- Завершили процесс, который держал соединение с `195.239.174.11:5558`, и удалили `/tmp/FULFFq`.
- Включили одобрение новых регистраций и удалили учётку `Script Kiddie`.



WSO2. Защита маршрута загрузки

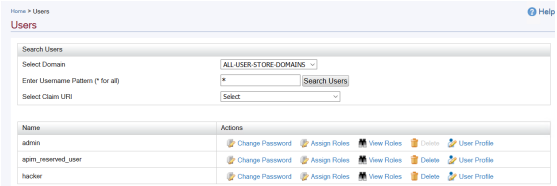
- В журнале нашли запрос к `/fileupload/toolsAny` и обращения к `exploit.jsp`.
- Завершили процесс `payload.elf` и удалили оба вредоносных файла.
- Ограничили доступ к `/fileupload` в `deployment.toml`. Запрос без авторизации получил **HTTP 401**.

```
user@wso2-virtual-machine: $ wget --no-check-certificate --max-redirect=0 --post-data='' -S -O /dev/null https://10.10.2
.27:9443/fileupload/toolsAny
--2026-11-10 00:58:23--  https://10.10.2.27:9443/fileupload/toolsAny
Connecting to 10.10.2.27:9443... connected.
WARNING: cannot verify 10.10.2.27's certificate, issued by 'CN=localhost,OU=WSO2,O=WSO2,L=Mountain View,ST=CA,C=US':
  Unable to locally verify the issuer's authority.
    WARNING: certificate common name 'localhost' doesn't match requested host name '10.10.2.27'.
HTTP request sent, awaiting response...
  HTTP/1.1 401
  WWW-Authenticate: realm user=""
  Transfer-Encoding: chunked
  Date: Mon, 09 Nov 2026 17:58:24 GMT
  Keep-Alive: timeout=60
  Connection: keep-alive
  Server: WSO2 Carbon Server

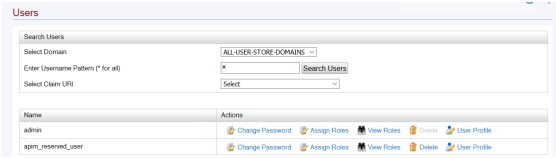
Username/Password Authentication Failed.
```

WSO2. Удаление посторонней учётной записи

До удаления



После удаления



В панели Carbon удалили учётную запись **hacker** и повторно проверили список пользователей.

Section 3

Результаты

Итог проверки на полигоне

Узел	Что проверили	Статус Ampire
Bitrix	Главная восстановлена, маршрут `vote` возвращает `403`	Оба пункта устранены
GitLab	Обратное соединение закрыто, `Script Kiddie` удалена	Оба пункта устранены
WSO2	Маршрут загрузки возвращает `401`, `hacker` удалён	Оба пункта устранены

Оформили три карточки инцидентов. Все шесть пунктов Ampire получили статус «Устранено».